



VULNERABILITY MANAGEMENT PIPELINE

OpenVAS Scan → DefectDojo Import → Prioritisation

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 2



1. Project Overview

This report documents the construction and execution of a Vulnerability Management Pipeline as part of the CyArt Red Teaming Internship (Week 2, Task 3). The pipeline connects three stages: automated vulnerability scanning with OpenVAS against the Metasploitable2 target, structured export of scan results, and centralised tracking and prioritisation within the DefectDojo vulnerability management platform.

The goal is to demonstrate how security teams systematically discover, triage, and manage vulnerabilities at scale — a foundational skill for both defensive and offensive security practitioners.

Stage 1	Stage 2	Stage 3	Vulns Prioritised
OpenVAS Scan	Export Results	DefectDojo Import	3 Findings

1.1 Lab Environment

Scanner Host	Kali Linux · 192.168.1.100 · OpenVAS / GVM 22.x
Scan Target	Metasploitable2 · 192.168.1.101 · Ubuntu 8.04 LTS
DefectDojo	Running on 192.168.1.100:8080 (Docker installation)
Network	192.168.1.0/24 · VMware Host-Only · Isolated lab
Export Format	XML (OpenVAS native) · also CSV for DefectDojo import

1.2 Tools Overview

Tool	Version	Role
OpenVAS / GVM	22.x	Automated vulnerability scanner — discovers CVEs, misconfigs, weak services on the target
Greenbone Security Assistant (GSA)	Web UI	Browser-based front-end for OpenVAS scan management and report export
Metasploitable2	VM Image	Deliberately vulnerable Linux target hosting numerous exploitable services
DefectDojo	2.x (Docker)	Open-source vulnerability management platform — import, track, prioritise findings



2. OpenVAS Vulnerability Scan

OpenVAS (Open Vulnerability Assessment System), part of the Greenbone Vulnerability Manager (GVM) suite, performs an authenticated or unauthenticated network scan against the target. It checks thousands of vulnerability tests (NVTs — Network Vulnerability Tests) covering CVEs, configuration weaknesses, outdated software, and dangerous open services.

2.1 Starting OpenVAS

Start the GVM stack and verify all services are running:

```
sudo gvm-start
sudo gvm-check-setup      # verify all services healthy
# Open browser: https://127.0.0.1:9392 (Greenbone Security
Assistant)
```

2.2 Creating the Scan Target

In the GSA web interface, configure the scan target for Metasploitable2:

- Navigate to: Configuration → Targets → New Target
- Name: Metasploitable2-Lab
- Hosts: 192.168.1.101
- Port List: All IANA assigned TCP (or Full and Fast)
- Save the target

2.3 Configuring and Launching the Scan

Create and launch a new scan task:

- Navigate to: Scans → Tasks → New Task
- Name: Metasploitable2-VulnScan
- Scan Config: Full and Fast (comprehensive NVT coverage)
- Target: Metasploitable2-Lab (created above)
- Scanner: OpenVAS Default Scanner
- Click Save → then click the Play (▶) button to start

```
# Alternatively via command line (gvm-cli):
gvm-cli --gmp-username admin --gmp-password admin \
  socket --socketpath /var/run/gvmd/gvmd.sock \
  --xml '<create_task><name>Metasploitable2-VulnScan</name>\
  <target id="TARGET-ID"/><config id="CONFIG-ID"/></create_task>'
```



2.4 Scan Completion & Results Summary

The scan completes and the GSA dashboard displays a results summary. Metasploitable2 is intentionally vulnerable and will generate a large number of findings across all severity levels.

Expected Scan Results

Metasploitable2 typically produces 80–200+ findings on a Full and Fast scan, including multiple Critical and High severity vulnerabilities across FTP, HTTP, SSH, Samba, MySQL, and other exposed services.



3. Exporting Scan Results

After the scan completes, results are exported in XML format from OpenVAS for import into DefectDojo. DefectDojo supports the OpenVAS XML report format natively.

3.1 Export via GSA (Web UI)

- Navigate to: Scans → Reports → select the completed scan report
- Click the Download icon
- Format: XML (OpenVAS Results)
- Save file as: metasploitable2_openvas_report.xml

3.2 Export via Command Line

Alternative: export using gvm-cli to automate the pipeline:

```
# Get report ID first
gvm-cli --gmp-username admin --gmp-password admin \
  socket --socketpath /var/run/gvmd/gvmd.sock \
  --xml '<get_reports/>' | grep 'report id'

# Export report as XML
gvm-cli --gmp-username admin --gmp-password admin \
  socket --socketpath /var/run/gvmd/gvmd.sock \
  --xml '<get_reports report_id="REPORT-ID" \
  format_id="a994b278-1f62-11e1-96ac-406186ea4fc5"/>' \
  > metasploitable2_openvas_report.xml

# Verify export
ls -lh metasploitable2_openvas_report.xml
head -20 metasploitable2_openvas_report.xml
```



4. Importing Results into DefectDojo

DefectDojo is an open-source application security vulnerability management tool. It provides a centralised dashboard to import scanner results, manage findings, assign severity, track remediation status, and generate management reports across multiple engagements.

4.1 DefectDojo Installation (Docker)

If DefectDojo is not yet installed, deploy it via Docker Compose:

```
git clone https://github.com/DefectDojo/django-DefectDojo.git
cd django-DefectDojo
./dc-build.sh
./dc-up.sh
# Access at: http://localhost:8080
# Default credentials: admin / defectdojo (change immediately)
```

4.2 Creating a Product and Engagement

DefectDojo organises findings by Product → Engagement → Test. Set up the structure before importing:

Step 1 — Create a Product

- Navigate to: Products → Add Product
- Name: "Metasploitable2-Lab"
- Product Type: Research and Development
- Description: Intentionally vulnerable VM for red team practice
- Team Manager: Arsalan Rasool Rather

Step 2 — Create an Engagement

- Navigate to the product → Engagements → Add Engagement
- Name: "Week2-OpenVAS-Scan"
- Engagement Type: CI/CD or Interactive
- Target Start: 16 May 2025 · Target End: 16 May 2025
- Lead: Arsalan Rasool Rather

4.3 Importing the OpenVAS XML Report

- Navigate to the Engagement → Tests → Import Scan Results
- Scan Type: OpenVAS Parser (select from dropdown)
- Choose File: metasploitable2_openvas_report.xml
- Minimum Severity: Low (import all findings)
- Click Import



4.4 Verifying the Import

After import, navigate to the Test to verify all findings were correctly ingested:

- Check total findings count matches OpenVAS report
- Verify severity distribution (Critical / High / Medium / Low)
- Confirm CVE IDs and CVSS scores are correctly mapped
- Check that plugin names and descriptions are imported



5. Prioritised Vulnerabilities

From the full OpenVAS scan results, the following three vulnerabilities were selected for priority remediation based on CVSS score, exploitability, and business impact. All three represent remote, unauthenticated attack vectors with confirmed public exploit code available.

Vulnerability 1 — vsftpd 2.3.4 Backdoor

Field	Detail
Vulnerability Name	vsftpd 2.3.4 Backdoor Command Execution
CVE ID	CVE-2011-2523
CVSS Score	7.5 (HIGH)
CVSS Vector	AV:N/AC:L/Au:N/C:P/I:P/A:P
Affected Host	192.168.1.101 · Port 21/tcp · vsftpd 2.3.4
Description	The vsftpd 2.3.4 source code was compromised and contains a backdoor. Sending a username containing ':' causes the daemon to bind a root shell to port 6200, granting unauthenticated remote code execution as root.
Business Impact	Full system compromise — attacker gains root access, enabling data theft, pivot, ransomware, or persistence installation.
Exploitability	Trivial — Metasploit module exploit/unix/ftp/vsftpd_234_backdoor is one command.
Evidence	Wazuh alert: port 6200 opened; root shell confirmed during Week 2 attack simulation (CAP-2025-W2-001).
Remediation	Upgrade vsftpd to 3.x immediately. Disable FTP — use SFTP (SSH) instead. Block port 21 at firewall perimeter.
Priority Rank	#1 of 3 — Exploit in wild, active Metasploit module, unauthenticated remote root.



Vulnerability 2 — Samba 3.x Remote Code Execution (MS-RPC)

Field	Detail
Vulnerability Name	Samba 'username map script' Command Injection
CVE ID	CVE-2007-2447
CVSS Score	10.0 (CRITICAL)
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Affected Host	192.168.1.101 · Ports 139/445 tcp · Samba 3.0.20
Description	Samba 3.0.0 through 3.0.25rc3 allows remote attackers to execute arbitrary commands via shell metacharacters in the username field when the 'username map script' option is configured in smb.conf.
Business Impact	Complete system takeover — unauthenticated remote root access. Enables full lateral movement across the network segment.
Exploitability	Trivial — Metasploit module exploit/multi/samba/usermap_script is widely used and well-documented.
Evidence	OpenVAS NVT 'Samba MS-RPC Shell Command Injection' flagged on port 445 during scan.
Remediation	Upgrade Samba immediately to a patched version. Remove 'username map script' directive from smb.conf. Block SMB ports (139, 445) at network perimeter. Apply host-based firewall rules.
Priority Rank	#2 of 3 — CVSS 10.0 but ranked #2 as vsftpd was directly demonstrated in lab.



Vulnerability 3 — UnrealIRCd 3.2.8.1 Backdoor

Priority #3 — CVSS 7.5 — HIGH

Backdoored IRC daemon enabling remote code execution on port 6667

Field	Detail
Vulnerability Name	UnrealIRCd 3.2.8.1 Backdoor Command Execution
CVE ID	CVE-2010-2075
CVSS Score	7.5 (HIGH)
CVSS Vector	AV:N/AC:L/Au:N/C:P/I:P/A:P
Affected Host	192.168.1.101 · Port 6667/tcp · UnrealIRCd 3.2.8.1
Description	UnrealIRCd 3.2.8.1 distributed via certain mirrors contained a trojan/backdoor. Sending 'AB;' followed by a system command to the server triggers unauthenticated remote code execution.
Business Impact	Remote command execution without authentication. Attacker can run arbitrary commands as the IRCd process user, potentially escalating to root.
Exploitability	Trivial — Metasploit module exploit/unix/irc/unreal_ircd_3281_backdoor available.
Evidence	OpenVAS NVT 'UnrealIRCd Backdoor Detection' triggered on port 6667 during scan.
Remediation	Remove or replace UnrealIRCd immediately. If IRC is required, use a patched, verified build. Block port 6667 at firewall. Consider disabling IRC services entirely in production environments.
Priority Rank	#3 of 3 — Same CVSS as vsftpd but lower business relevance in this environment.



6. Prioritised Vulnerability Summary Table

The table below consolidates the three prioritised findings as they appear in DefectDojo, ready for triage and remediation assignment:

#	Vulnerability	CVE	CVSS Score	Port/Service	Exploitability	Remediation Priority
1	vsftpd 2.3.4 Backdoor	CVE-2011-2523	7.5 HIGH	21/tcp — FTP	Trivial (Metasploit)	Immediate
2	Samba username map script RCE	CVE-2007-2447	10.0 CRITICAL	139,445/tcp — SMB	Trivial (Metasploit)	Immediate
3	UnrealIRCd 3.2.8.1 Backdoor	CVE-2010-2075	7.5 HIGH	6667/tcp — IRC	Trivial (Metasploit)	High

6.1 Recommended Remediation Timeline

Vulnerability	Deadline	Owner	Status
vsftpd 2.3.4 Backdoor — CVE-2011-2523	Within 24 hours	System Admin	Open
Samba RCE — CVE-2007-2447	Within 24 hours	System Admin	Open
UnrealIRCd Backdoor — CVE-2010-2075	Within 72 hours	System Admin	Open



7. Pipeline Workflow Summary

The complete vulnerability management pipeline executed in this task follows these sequential steps:

Step	Stage	Action	Output
1	Environment Setup	Start OpenVAS (gvm-start); verify DefectDojo running on :8080	Both tools healthy and accessible
2	Target Config	Create scan target: Metasploitable2 (192.168.1.101) in GSA	Target object ready in OpenVAS
3	Scan Launch	Create and run 'Full and Fast' task against target	Active scan initiated
4	Scan Review	Review findings in GSA — sort by severity, review CVSS scores	Understanding of vulnerability surface
5	Export	Download report as XML from GSA Reports section	metasploitable2_openvas_report.xml
6	DefectDojo Setup	Create Product and Engagement in DefectDojo	Organisational structure ready
7	Import	Import XML via: Engagement → Import Scan Results → OpenVAS Parser	All findings imported and tracked
8	Prioritise	Filter by CVSS score; select top 3; add remediation notes	3 findings prioritised with SLA
9	Report	Document findings in this report with evidence and remediation	Management-ready deliverable

7.1 Key Observations

- OpenVAS identified dozens of exploitable vulnerabilities on Metasploitable2 — the three prioritised all have Metasploit modules confirming ease of exploitation.
- DefectDojo's OpenVAS parser correctly mapped all CVE IDs, CVSS scores, and plugin descriptions without manual editing.
- The DefectDojo findings workflow (Open → Under Review → Remediated → Closed) provides a clear audit trail for security teams.
- Automating the export and import (via gvm-cli + DefectDojo API) would make this pipeline suitable for CI/CD integration in a DevSecOps context.



8. Recommendations

#	Recommendation	Priority	Effort
1	Patch or remove all three backdoored services (vsftpd, Samba, UnrealIRCd) immediately	CRITICAL	Low
2	Replace FTP with SFTP across all systems — FTP transmits credentials in plaintext	CRITICAL	Low
3	Apply firewall rules to block ports 21, 139, 445, 6667 at the network perimeter	HIGH	Low
4	Run OpenVAS scans monthly — automate via cron + gvm-cli for continuous coverage	HIGH	Medium
5	Integrate OpenVAS with DefectDojo API for automated import without manual steps	HIGH	Medium
6	Set DefectDojo SLA policies to enforce remediation deadlines by severity	MEDIUM	Low
7	Expand scanning to include authenticated scans for deeper configuration analysis	MEDIUM	Medium
8	Add OpenVAS to a CI/CD pipeline to scan any new deployment before production	MEDIUM	High

9. Appendix

9.1 Screenshot Checklist

#	Section	Screenshot Description
1	2.1 — Start OpenVAS	GSA login page at https://127.0.0.1:9392
2	2.2 — Target Config	New Target form showing 192.168.1.101 and port list
3	2.3 — Scan Config	New Task form: target, scan config, scanner selected
4	2.3 — Scan Running	GSA task progress bar with status and target visible
5	2.4 — Results Summary	GSA results chart showing severity breakdown
6	2.4 — Findings List	GSA full findings list sorted by severity with CVEs
7	3.1 — Export	GSA report download dialog with XML format selected
8	3.2 — CLI Export	Terminal: gvm-cli export + ls -lh confirming XML file



9	4.1 — DefectDojo Home	DefectDojo dashboard at http://localhost:8080
10	4.2 — Add Product	DefectDojo Add Product form filled in
11	4.2 — Add Engagement	DefectDojo Add Engagement form filled in
12	4.3 — Import Form	Import Scan Results — OpenVAS Parser, XML file chosen
13	4.3 — Import Success	Post-import screen showing findings count and breakdown
14	4.4 — Findings List	DefectDojo all imported findings list view
15	5.1 — Vuln 1 Detail	DefectDojo: vsftpd finding detail (CVE-2011-2523)
16	5.2 — Vuln 2 Detail	DefectDojo: Samba finding detail (CVE-2007-2447)
17	5.3 — Vuln 3 Detail	DefectDojo: UnrealIRCd finding detail (CVE-2010-2075)
18	6 — Summary View	DefectDojo: filtered findings list showing all 3 prioritised vulns

9.2 OpenVAS NVT References

vsftpd 2.3.4 Backdoor	NVT OID: 1.3.6.1.4.1.25623.1.0.103203
Samba username map script	NVT OID: 1.3.6.1.4.1.25623.1.0.100218
UnrealIRCd Backdoor	NVT OID: 1.3.6.1.4.1.25623.1.0.100237
DefectDojo OpenVAS Parser	Supports OpenVAS XML report format natively via scan import